SOC DEFENSIVE ARCHITECTURE REPORT

PhishHunter Live

Ficha Técnica de Arquitectura de Software y Auditoría de Seguridad

Versión: v2.4.0
Fecha: Octubre 2026
Clasificación: Confidencial / Técnico

1. RESUMEN EJECUTIVO

¿Qué es la aplicación? PhishHunter Live es una solución integral de ciberseguridad defensiva basada en arquitectura web moderna orientada a la detección, análisis de amenazas y contención pasiva contra ataques de **Quishing (QR Phishing)**, Spearphishing y distribución de malware a través de hipervínculos.

Problema que resuelve: Los códigos QR codifican datos en una matriz bidimensional visualmente indescifrable para el ojo humano. Esto genera un vector de ataque masivo donde cibercriminales suplantan marcas legítimas, redirigen a través de acortadores y alojan portales de cosecha de credenciales en infraestructuras desechables (túneles reversos, DNS dinámico y subdominios falsificados). Los navegadores convencionales no alertan al usuario antes de visitar el enlace, exponiendo sus credenciales o dispositivos.

Propuesta de Valor:

- **Aislamiento Preventivo en Sandbox (Zero-Risk):** Inspecciona y renderiza de forma pasiva el contenido de páginas sospechosas neutralizando cualquier script malicioso o descarga silenciosa (Drive-by).
- **Soporte Nativo de Estándares Financieros EMVCo:** Decodifica y valida pagos móviles legítimos (Plin, Yape, Pix) leyendo sus etiquetas TLV sin generar falsos positivos de phishing.
- **Evaluación Cuantitativa de Riesgo (Risk Score 0-100):** Asigna una ponderación matemática transparente basada en infracciones normativas y severidad técnica.

2. STACK TECNOLÓGICO Y ENTORNO OPERACIONAL

Componente	Tecnología / Framework	Versión	Rol y Función Arquitectural
Backend Runtime	Python	3.11.9	Ejecución de motores heurísticos, trazabilidad de red y API REST.
API REST	FastAPI	>= 0.110.0	Servidor web asíncrono ASGI de alto rendimiento con validación de tipos Pydantic.
Servidor ASGI	Uvicorn [standard]	>= 0.28.0	Servidor de producción con gestión de sockets asíncronos y entrega de SPA.
Visión Computacional	OpenCV Headless	>= 4.9.0.80	Decodificación matricial QR (cv2.QRCodeDetector) y localización de esquinas.
Procesamiento Numérico	NumPy	>= 1.24.0	Transformación de arrays de píxeles y buffers de imagen.
Cliente HTTP / TLS	Requests / Urllib3	>= 2.31.0	Rastreo paso a paso de redirecciones y auditoría criptográfica SSL/TLS.
Sandbox Pasivo	BeautifulSoup4	>= 4.12.0	Extracción OpenGraph y desinfección estricta de DOM HTML (mitigación CWE-79).
Frontend SPA	React	^19.2.8	Biblioteca de interfaz de usuario reactiva, modular y con diseño SOC Dark Glassmorphism.
Frontend Build Tool	Vite	^8.3.0	Compilación, minificación y empaquetado de producción de la SPA.
Iconografía SOC	Lucide React	^1.57.0	Set de vectores para indicadores de estado, auditoría y alertas.
Suite de Pruebas	Pytest	>= 8.0.0	25 pruebas automatizadas de cobertura para motores heurísticos y API.

Base de Datos Relacional y Modelo de Almacenamiento

Motor implementado: SQLite 3 (ACID transaccional nativo de Python 3.11). Archivo: `database/phishhunter.db`.

Propósito: Registro inmutable de auditoría forense para cumplir con el **Control A.8.15 de ISO/IEC 27001**. Almacena marcas de tiempo UTC, cargas útiles crudas, destinos finales resueltos, número de saltos, Risk Score, firmas activadas e IP cliente.

Optimización: Cuenta con índices B-Tree sobre `timestamp DESC` y `risk_level` para agilizar consultas analíticas y exportaciones a CSV/JSON.

Infraestructura y Despliegue en la Nube

- **Arquitectura Single-Port:** FastAPI entrega la API REST bajo `/api/*` y sirve la SPA de React desde `frontend/dist` en un único puerto y dominio unificado.
- **Plataforma: Render Cloud Platform** (Web Service, Entorno Linux nativo).
- **Infraestructura como Código (render.yaml):** Automatiza el build (`pip install` + `npm run build`) y arranque con `uvicorn api:app --host 0.0.0.0 --port $PORT`.
- **Repositorio GitHub:** `https://github.com/anthonyrsava2004-bot/phishhunter-live-react` (rama `main`).

3. FUNCIONALIDADES Y FLUJO DE TRABAJO

1. **Captura Multicanal:** Subida de imágenes QR, escaneo con cámara web o inserción manual de URLs.
2. **Decodificación y Triaje:** OpenCV extrae la carga útil. Si es un pago EMVCo (Plin/Yape), parsea los tags TLV y emite veredicto seguro inmediato. Si es URL web, pasa al motor de red.
3. **Rastreo Pasivo de Red (URLTracer):** Sigue saltos HTTP (301, 302, 307, 308) midiendo latencias, detectando bucles y evaluando degradaciones criptográficas (SSL Strip).
4. **Inspección Heurística Multicapa (HeuristicEngine):**
   - **Inteligencia Global:** Consulta en tiempo real a listas negras de malware y phishing (**SURBL Multi Feed** y **Spamhaus DBL**).
   - **Ataques Homógrafos (RFC 5890):** Detecta prefijos Punycode (`xn--`) y caracteres cirílicos/griegos idénticos a letras latinas.
   - **Typosquatting y Suplantación (NIST SP 800-63B):** Algoritmo Levenshtein contra más de 110 entidades protegidas (banca peruana, LATAM y global) y detección de *Subdomain Spoofing* (ej. `paypal.com.attacker.com`).
   - **Infraestructura Abusada:** Identifica túneles efímeros/DDNS (`duckdns.org`, `ngrok`) y plataformas serverless gratuitas combinadas con señuelos de banca.
   - **Estado del Servidor:** Penaliza destinos no resueltos, caídos o bloqueados (sinkhole).
5. **Aislamiento en Sandbox Pasivo:** Descarga hasta 512 KB de HTML, detecta formularios de captura de credenciales (`<input type='password'>`), sanitiza el DOM eliminando scripts e iframes y genera vista previa inofensiva.
6. **Cálculo de Risk Score y Salidas:** Emite Risk Score (0-100), nivel cualitativo (SEGURO 🟢, SOSPECHOSO 🟡, CRÍTICO / QUISHING 🔴), telemetría de saltos y matriz de alertas.

4. CONTROLES DE SEGURIDAD Y ESTÁNDARES INTERNACIONALES

Estándar / Marco	Control / Cláusula	Mecanismo Técnico en PhishHunter Live
ISO/IEC 27001:2022	Control A.8.15 (Logging Forense)	Registro inmutable en base de datos SQLite con IP, URL, banderas y timestamp UTC.
ISO/IEC 27001:2022	Control A.8.20 (Aislamiento Defensivo)	Sandbox pasivo que desinfecta HTML y evita ejecución de scripts en el cliente.
ISO/IEC 27001:2022	Control A.8.24 (Uso de Criptografía)	Auditoría TLS en socket, validación CA y penalización por degradación HTTPS-HTTP.
OWASP ASVS v4.0	V5.1 / CWE-601 (Open Redirects)	Rastreo de saltos HTTP con detección de pivoteo entre dominios no relacionados.
OWASP ASVS v4.0	V5.3 / CWE-79 (Mitigación de XSS)	Purga estricta de tags interactivos, scripts y eventos on* en BeautifulSoup.
NIST SP 800-63B	Sección 5 (Identidad Digital)	Mitigación de Typosquatting mediante ratio de similitud Levenshtein y combosquatting.
CIS Controls v8	Control 4.1 (Configuración Segura)	Detección de puertos no convencionales (:8080, :4444) y uso de IPs directas.
RFC 5890	IDNA (Internationalized Domains)	Detección de dominios con prefijo xn-- y caracteres visualmente confusables.
MITRE ATT&CK	T1566.002 / T1583.001	Controles contra Spearphishing Quishing y adquisición de dominios fraudulentos.

Auditoría de Inyecciones (CWE-89): El 100% de las consultas a base de datos están parametrizadas con tuplas y cursores seguros, descartando cualquier riesgo de Inyección SQL.